

PURPLEWATCH

Rapport final - Laboratoire Purple Team

Simulation ATT&CK, détection Wazuh et validation E2E

Résumé exécutif

PurpleWatch est un laboratoire Purple Team isolé. Il permet de lancer des techniques MITRE ATT&CK contrôlées avec Caldera, de produire une télémétrie endpoint avec Sysmon ou auditd, puis de la détecter et de l'explorer dans Wazuh.

Le résultat recherché n'est pas seulement l'exécution d'une commande : chaque scénario doit démontrer une chaîne de preuve complète, de l'émulation jusqu'à l'alerte enrichie de son identifiant ATT&CK.

Périmètre validé

- Deux endpoints : PW-WIN11-01 et PW-LINUX-01.
- Orchestration Caldera et connectivité chiffrée Tailscale.
- Détection centralisée Wazuh avec règles PurpleWatch maintenues comme du code.

1. Architecture et déroulement E2E

Caldera orchestre les abilities sur les agents Sandcat. Les exécutions génèrent des événements endpoint : Sysmon sous Windows et auditd sous Linux. Les agents Wazuh transmettent ensuite ces événements au manager Wazuh, qui applique les règles PurpleWatch avant l'indexation et la consultation dans Threat Hunting.

Composant	Rôle	Canal principal
PW-CALDERA-01	Orchestration Caldera et C2	HTTP 8888 via Tailscale
PW-WIN11-01	Sandcat, Sysmon, Wazuh Agent	Wazuh 1514 vers manager
PW-LINUX-01	Sandcat, auditd, Wazuh Agent	Wazuh 1514 vers manager
PW-WAZUH-01	Manager, indexer, dashboard	Threat Hunting

Chaîne de validation

- Caldera lance une ability ATT&CK sur un endpoint autorisé.
- Sysmon ou auditd collecte la création du processus concerné.
- Wazuh reçoit, décode et applique la règle PurpleWatch.
- L'alerte est recherchée avec l'hôte, la règle et la technique MITRE.

2. Couverture et résultats

Les règles PurpleWatch validées sont les suivantes.

Endpoint	Technique	Commande observée	Règle
Windows	T1082	systeminfo.exe	100100
Windows	T1057	tasklist.exe	100101
Windows	T1087.001	net user	100102
Windows	T1016	ipconfig /all	100103
Linux	T1082	uname	100104
Linux	T1057	ps -ef / Atomic ps	100105

Retests mesurés

Après le rétablissement du collecteur Windows, deux retests E2E ont été mesurés : T1082 a produit l'alerte 100100 en 36,817 secondes ; T1057 a produit l'alerte 100101 en 16,526 secondes. Ces chiffres distinguent le temps de l'exécution Caldera du temps d'apparition de l'alerte dans Wazuh.

3. Démarche Purple Team et résolution de problèmes

Une absence d'alerte n'est pas un succès de scénario. Elle déclenche une analyse de la chaîne : exécution, collecte, transport, décodage et règle. Le correctif est ensuite retesté jusqu'à l'obtention d'une alerte exploitable.

- Linux : auditd a été ciblé avec la clé purplewatch_execve ; la règle 100105 reconnaît /usr/bin/ps.
- Windows : le collecteur Wazuh a été redémarré puis la règle 100100 a été validée par retest.
- Caldera : l'agent doit être alive, trusted avant le lancement d'une opération.

4. Limites, apprentissages et prochaines étapes

Limites connues

La tâche planifiée Windows de persistance Sandcat a renvoyé 0x8007042B dans ce laboratoire. La procédure de démonstration utilise donc le script manuel C:\Users\Public\Start-PurpleWatch-Sandcat.cmd. Cette limite est documentée et ne doit pas être présentée comme résolue.

Apprentissages

- Distinguer l'émulation d'une attaque, la télémétrie brute et la détection enrichie.
- Traiter les règles Wazuh comme du code : versionner, valider, tester et documenter.
- Préparer une démonstration avec des vérifications de santé et un scénario de secours.

Prochaines étapes

- Automatiser les contrôles de santé et la mesure de latence E2E.
- Finaliser une persistance Windows testée et réversible.
- Étendre la couverture ATT&CK et ajouter des tests de non-régression.

Conclusion

PurpleWatch démontre un cycle Purple Team concret : émuler, observer, détecter, corriger et retester. Le livrable réunit l'architecture, les règles, les preuves de validation et les limites connues pour rendre le laboratoire compréhensible et reproductible.